Phát hiện botnet IoT bằng autoencoder nhẹ

Đề tài DT043 · Bài giữa kỳ An toàn Bảo mật Hệ thống thông tin

Tên: Hoàng Thanh Trà

MSSV: 1150080120

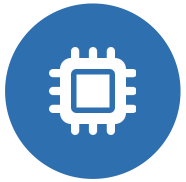
Lớp: 11CNPM2

Bài toán và mục tiêu



Thiết bị IoT dễ bị chiếm

Mật khẩu mặc định, ít vá – Mirai, BASHLITE chiếm hàng loạt để DDoS



Edge có tài nguyên hạn chế

Bộ phát hiện phải nhỏ (KB), nhanh (µs), ít RAM



Mỗi thiết bị một hành vi

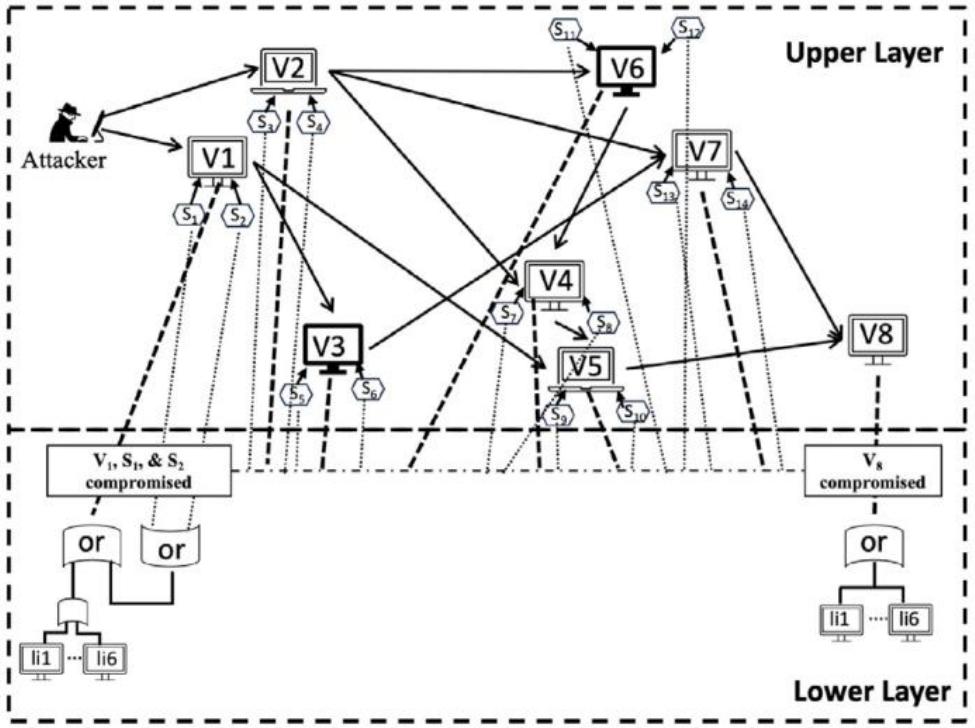
Học lưu lượng bình thường riêng từng thiết bị

Mục tiêu đề tài

1. Phát hiện botnet ngay tại edge bằng autoencoder nhẹ, lượng tử hóa int8
2. Tái lập có chọn lọc bài báo chính (3-layer THARM)
3. Dùng cảnh báo của AE kích hoạt Moving Target Defence lai

6 câu hỏi nghiên cứu, tiêu chí chốt trước khi chạy (SHA-256 trong nhật ký)

Bài báo nói gì và thiếu gì



Hình 3 của bài báo: mô hình 3-layer THARM

Bài toán

Đánh giá kết hợp MTD (shuffle, diversity, redundancy) cho IoT theo rủi ro, chi phí, tài nguyên

Phương pháp

Đồ thị tấn công 3 tầng THARM: 8 máy ảo, 32 CVE; MTD theo chu kỳ 10 phút

Kết quả

Shuffle + diversity cho rủi ro thấp nhất

Hạn chế

Chỉ mô phỏng, không có bộ phát hiện kích hoạt MTD, không công bố mã

→ Đề tài: Track A phát hiện bằng autoencoder (Meidan 2018) · Track B tái lập THARM + MTD lai do cảnh báo AE kích hoạt

Dữ liệu và phương pháp

7.06M

dòng N-BaIoT · 9 thiết bị · 107 file khớp SHA-256

157,779

dòng trùng lặp bị loại

5.5–61.8×

tấn công nhiều hơn benign → dùng macro-F1, FPR

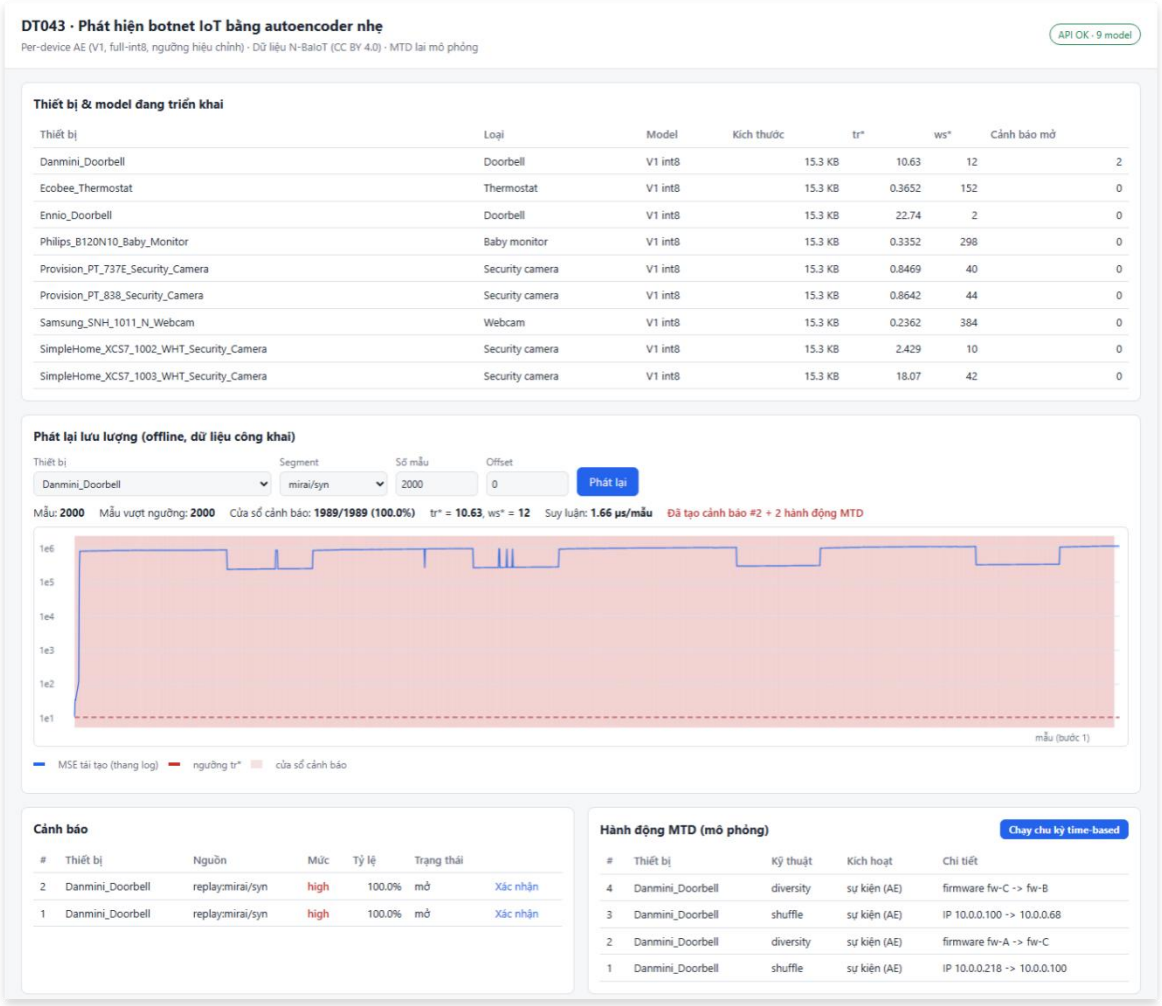
DStrn · huấn luyện | **DSopt · chọn ngưỡng tr*, cửa sổ ws*** | **Test · benign + mọi tấn công**

chia benign theo thời gian 1/3 · 1/3 · 1/3, đệm 500 dòng, scaler chỉ fit trên DStrn – chống rò rỉ



Baseline B0 = AE Meidan 115-86-58-38-29-… (36.876 tham số) · Biến thể V1 = 115-32-8-32-115 (8.059 tham số, 21,9%) · so sánh Isolation Forest

Hệ thống 4 tầng và demo



56 test tự động · server: uvicorn backend.app.main:app → http://127.0.0.1:8000/

AI: huấn luyện, int8, xuất gói có SHA-256

Backend: FastAPI, từ chối gói model bị sửa

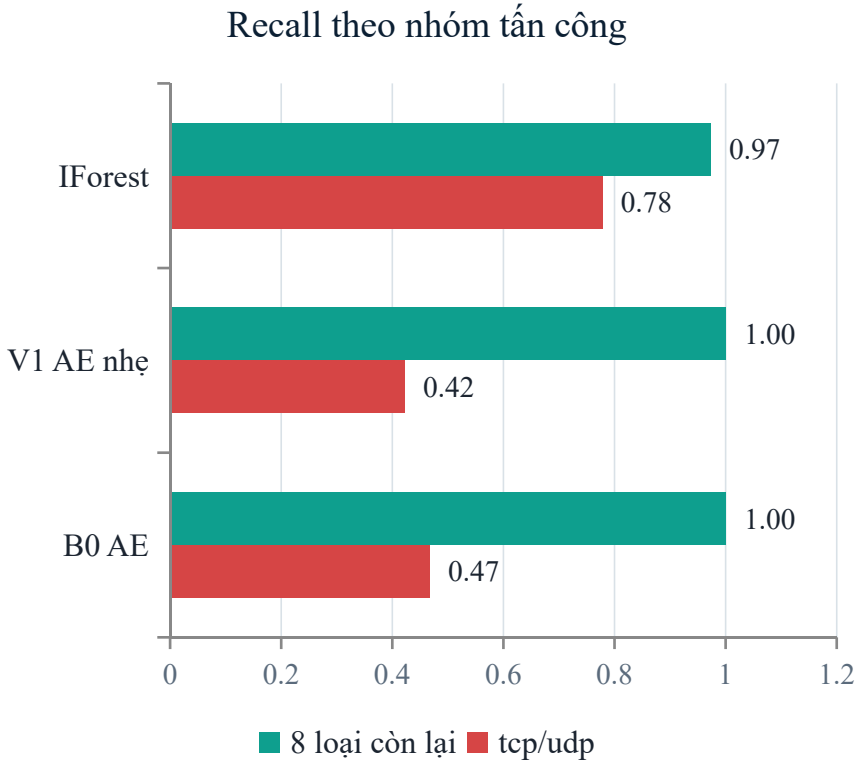
CSDL: SQLite: cảnh báo, hành động MTD

Dashboard: phát lại dữ liệu, biểu đồ MSE

Kết quả demo

- mirai/syn (Danmini): 1989/1989 cửa sổ cảnh báo → shuffle IP + đổi firmware
- benign (Ennio): 0 cảnh báo – không báo động giả
- gafgyt/tcp (Ennio): 0 cảnh báo – điểm yếu đã phân tích

Kết quả phát hiện và chạy trên edge



0.0025

FPR của B0 (Meidan: 0.007)

15.3 KB

model V1 int8 (tiêu chí ≤ 50 KB)

0.822

TPR của B0 (Meidan: 100%)

10.8 µs

p95 / mẫu trên 1 lõi E-core (≤ 1000 µs)

Flood tcp/udp giả mạo nguồn: mỗi gói như "luồng mới" nên giống benign, MSE nằm dưới ngưỡng. RAM tăng 4.6 MB, 102,899 mẫu/giây → RQ5 (edge) đạt.

Tái lập bài báo: khớp đến đâu

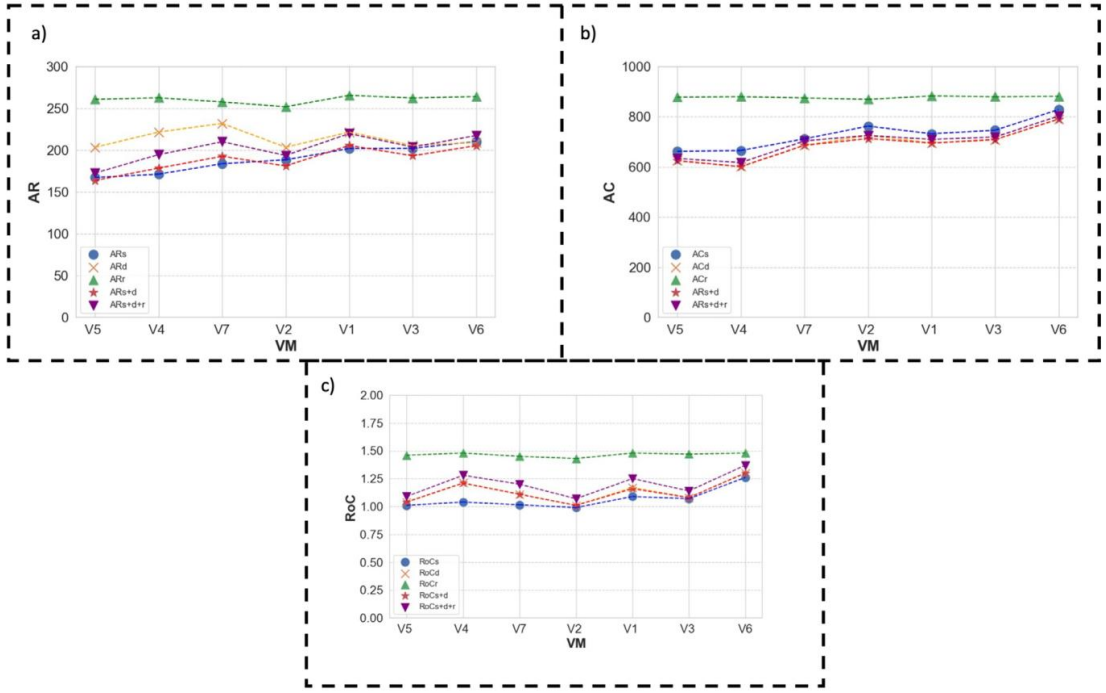
6/6
rủi ro từng VM khớp ±0.01

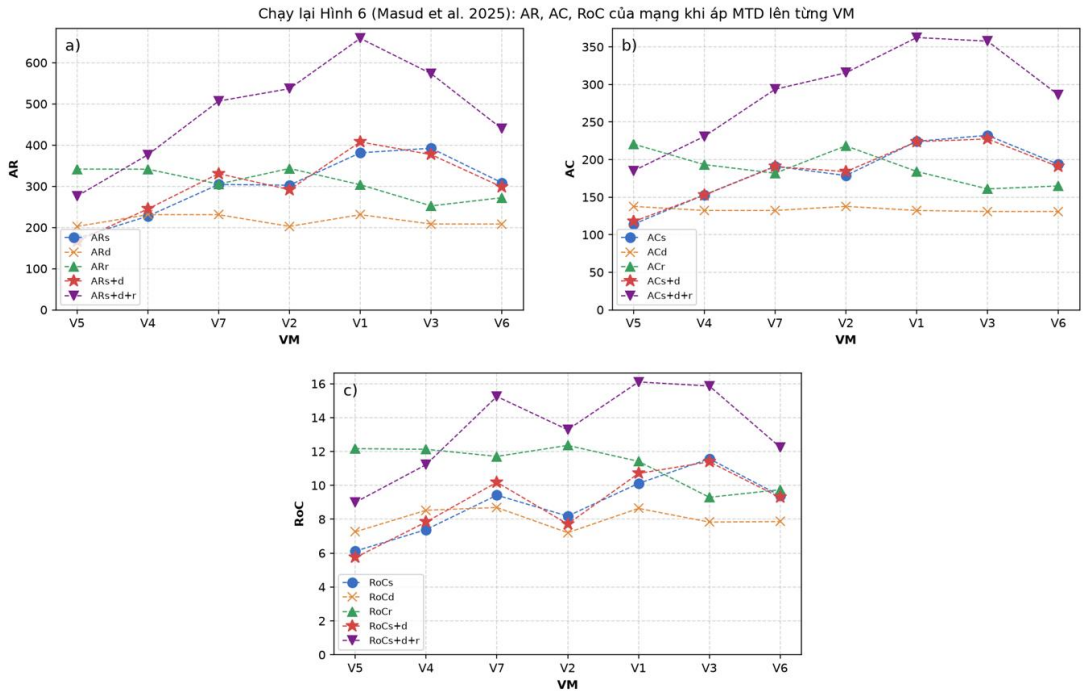
3/3
đường tấn công, lệch −0.8%

6/7
kết luận định tính

7/7
VM khớp ở Hình 6 (diversity)

Hình 6 – bài báo (trái) · chạy lại – DT043 (phải)





Kết luận và hướng tiếp theo

RQ	Giá trị đo	Kết luận
RQ1	TPR=0.8222, FPR=0.0025	**Không đạt**
RQ2	thắng 4/9, p=0.2852	**Không đạt**
RQ3	tham số 21.9%, Δ=+0.0171	**Không đạt**
RQ4	Δ=-0.0278, kích thước 45.5%	**Không đạt**
RQ5	p95=10.8 µs, 15.3 KB, ΔRSS=4.6 MB	**Đạt**

Tiêu chí chốt trước, không chỉnh theo kết quả; báo cáo đủ 468 lần chạy.

- AE bắt gần tuyệt đối 8/10 loại tấn công, FPR rất thấp; bỏ sót flood tcp/udp giả mạo nguồn
- V1 int8 15 KB, ~10 µs/mẫu – khả thi cho edge
- Tái lập bài chính: khớp mức VM, đường, 6/7 kết luận
- Tiếp theo: đặc trưng cho flood giả mạo · Raspberry Pi thật · MTD trên mạng thật